



Chapter Title: Case studies

Book Title: The Cloud

Book Subtitle: Understanding the Security, Privacy and Trust Challenges

Book Author(s): Neil Robinson, Lorenzo Valeri, Jonathan Cave, Tony Starkey, Hans Graux, Sadie Creese and Paul Hopkins

Published by: RAND Corporation

Stable URL: <https://www.jstor.org/stable/10.7249/tr933ec.12>

JSTOR is a not-for-profit service that helps scholars, researchers, and students discover, use, and build upon a wide range of content in a trusted digital archive. We use information technology and tools to increase productivity and facilitate new forms of scholarship. For more information about JSTOR, please contact support@jstor.org.

Your use of the JSTOR archive indicates your acceptance of the Terms & Conditions of Use, available at <https://about.jstor.org/terms>



This content is licensed under a RAND Corporation License. To view a copy of this license, visit <https://www.rand.org/pubs/permissions.html>.



RAND Corporation is collaborating with JSTOR to digitize, preserve and extend access to *The Cloud*

JSTOR

7.1 **Introduction**

As has been illustrated in the previous chapters of this report there are a range of concerns, challenges and uncertainties relating to the security, privacy and trust issues associated with the use of cloud computing. These may be inherent in the underlying technical components or drivers of cloud computing, such as virtualisation and web services, or the legal or regulatory frameworks that surround cloud computing, such as the identification of applicable law and data protection/privacy compliance.

In any respect, the characteristics of cloud computing (shared to a certain extent with outsourcing) relating to security or privacy may be seen as both a challenge and an opportunity. For example, the degree of granularity regarding the locations of stored data in the cloud may be linked to the negotiating power of the cloud customer and may in certain cases be in conflict with the prevailing regulatory framework (for European cloud customers, the legal requirements stemming from privacy and data protection law). Equally, the wealth of data created by the logging functionality inherent in the cloud computing model presents something of a security opportunity in terms of understanding exactly what is going on in an ICT infrastructure, especially for SMEs or organisations that might not otherwise have the know-how or resources to implement such functionalities on their own. Furthermore the possibilities of quickly and seamlessly re-provisioning infrastructure also represent an opportunity in respect of availability and resilience.

7.2 **Initial classification of case studies**

This chapter takes a specific look at real life case studies,¹³³ to gain insight into how the issues discussed above are handled in practice. The data collection for these case studies was conducted between May and August 2010.

Given the role of use cases in the study, it is important to select representative examples which provide a realistic overview of cloud computing. In that respect, several classifications may be proposed.

A first important distinction lies with the control of the cloud service:

¹³³ The term ‘case studies’ is used to refer to actual instances of implementation, as distinct from ‘use cases’, which are generic classifications of types of implementation (eg, ‘a public sector healthcare concern’)

- **Private clouds** (internal clouds): the user controls every aspect of a cloud (eg, a company creates its own internal cloud service for internal use only); in other words, while cloud technologies are used, no external cloud service provider is involved, eliminating many of the security concerns defined above.
- **Public clouds** (external clouds): the cloud itself is made available to external users as a service.

The motivation behind the operation of the cloud service can be used as a second key characteristic:

- **Commercial cloud computing services:** operated and offered as for-profit ventures.
- **Public sector cloud computing services:** operated and offered for the public good; typically, in these cases a cloud service is offered by a public body and offered only to other public bodies or other entities which somehow contribute to a public service.
- **Scientific/academic/research cloud computing services:** operated and offered to advance scientific or technical progress in various disciplines eg, by pooling/sharing resources.
- **Community-driven cloud computing services:** where the cloud serves to establish, promote or interconnect more- or less-defined communities of users.

A third classification could be based on the degree of sensitivity of the usage of the cloud service, or in other words the risk it presents to the user. While much more nebulous and subjective than the distinctions above, it nonetheless presents a crucial characteristic when assessing the viability of a cloud project. One could distinguish:

- **Low risk** use cases: where data loss or service interruption would have no serious impact on the user's activities. No crucial data or services are entrusted to the cloud, and the risk of significant damage is limited. An example would be using the cloud for redundant backup of non-vital data, or for added value services which would only cause minor discomfort in case of interruption.
- **Medium risk** use cases: where data loss or service interruption would have a noticeable impact on the user's activities resulting in real damages but without being business critical. Examples include email hosting in the cloud, or relying on cloud-based human resource management systems (for businesses which do not rely entirely on email communications or on HR management for their business activities).
- **High risk** use cases: where data loss or service interruption would have a detrimental impact on the user's activities, and could result in significant and broader harm. Examples might include entrusting sensitive (eg, financial or health data) or classified national security data to the cloud.

Finally, the type of service being provided can be considered a deciding factor, with IaaS, PaaS, SaaS and HaaS being the main possibilities.

Within the scope of the present project, it would not be feasible to achieve full coverage of each of these archetypes. Rather, it seems desirable to make an optimal selection, based on the main observed uses of cloud computing. This issue will be briefly examined below.

7.3 **Observations on case studies in practice**

Both the literature and presentations from the SecureCloud 2010 conference illustrated several trends that may be relevant for the selection of use cases to be examined:

- Firstly, both private and public cloud initiatives were presented during this conference. For the purposes of this study, public initiatives appear to be more relevant, since security and privacy risks are much easier to identify, address and avoid in internal projects.
- The main emphasis was on commercial and public sector clouds; thus, both of these categories would need to be represented in the selected use cases. Scientific clouds and community-driven clouds would be interesting as well (especially since community-driven clouds may be more prone to privacy risks), but appear to be less common today.
- High-risk use cases are few and far between; thus it seems inevitable that most use cases fall into the low and medium risk categories.
- Finally, with respect to cloud service types, IaaS and HaaS cloud services seem less interesting for the purposes of this study, since although they may share the concerns of multi-tenancy and dynamic migration they are less fundamentally different from traditional outsourcing models than PaaS and SaaS models.

7.4 **Matrix of case study typology**

Table 4, below, indicates the key characteristics of the selected case studies:

Table 4. Characteristics of case studies

Case study	Cloud service model used by case study subject	Service model offered to end users	Risk	Rationale
Danish National IT Agency	IaaS	Traditional (non-cloud)	Low to Medium	This case study represents a social network and knowledge sharing platform. However, there are concerns regarding the use of personal data collected as part of this implementation
City of Los Angeles	SaaS	SaaS	Medium	Although this case study exists in a different regulatory environment to that of Europe, there are still overarching security

				and sensitivity lessons associated with the storage of criminal record data in the cloud. The LAPD was a major user community in this implementation
EU Member State eHealth cloud	IaaS	SaaS	Medium to High	This case study covers the use and processing of health related personal data in the cloud

7.5 **Case Study 1: the Danish National IT and Telecom Agency**

The use case owner is the Danish National IT and Telecom Agency (NITA),¹³⁴ part of the Ministry of Science, Technology and Innovation. It is a public service tasked with establishing the groundwork for the digitalisation of Denmark, and is based on five strategic objectives:

- Denmark should have an electronic communications infrastructure ranking among the best in the world.
- The Danes should obtain the necessary competencies to utilise this infrastructure optimally.
- The Danes should feel secure and confident when using the infrastructure.
- The Danes will use the infrastructure in practice because it offers valuable and useful content.
- NITA will contribute actively to the reduction of energy consumption and environmental hazards in Denmark.

As a part of its remit, NITA supports the development and deployment of IT architecture and standards in the Danish public sector. In a January 2010 policy paper on Denmark as a high-tech society, an independent committee appointed by the Ministry of Science recommended that:

- Denmark should become a leading cloud (and IT in general) nation. The government should invest heavily in cloud computing. Due to its size, the public sector would be an attractive customer for providers of cloud computing and of cloud-based services, and could help drive the resolution of challenges related to privacy, data security, expenses, etc.
- The public sector should undertake projects where cloud computing is used. The focus should be to gather experience and publish guidance on the use of cloud computing, among other things to ensure clear and attractive subscription terms and standard agreements, new paradigms for safety, etc.

¹³⁴ See (as of 22 November 2010) <http://www/itst.dk/>

NITA does not procure or provide IT solutions for other public sector entities; rather, its task is to support IT development in Denmark in general. The experiences of NITA are nevertheless also intended to aid private bodies.¹³⁵

7.5.1 Description of the use case

The use case concerns the migration to the cloud of the social network Digitaliser.dk,¹³⁶ which is a community managed by NITA aiming to provide public sector institutions and suppliers (although anyone is free to join) with information about the digitalisation of the Danish public sector and to allow users to exchange information about the issue.

In other words, Digitaliser.dk is a social network, a tool for development and knowledge sharing, a forum for the digitalisation of Denmark, and both a formal central repository of information on data interchange standards and a big open digital playground. It is a creative space for everyone involved in digitising the public sector.¹³⁷

As NITA points out in the English version of the site, 'Digitaliser.dk aims to stimulate development and adoption of digital content and business models by utilising Web 2.0 technologies and public data and digital resources. With digitaliser.dk, the Danish government has created a new model of partnership between the tech community and government which paves the way for more direct communication between the public sector, citizens, and businesses. Citizens and businesses are no longer passive recipients of public information but participate in dialogue and knowledge sharing with the public sector.'¹³⁸

Digitaliser.dk was already operational before the migration to the cloud, using a different, more traditional technical hosting model. The migration started in November 2009 and at that time Digitaliser.dk had some 2,500 registered users. NITA decided to transfer the community to the cloud firstly in order to assess the benefits of the cloud (including in terms of innovation, efficiency, cost effectiveness and environmental impacts¹³⁹) and secondly to reduce hosting costs. The primary goal was, however, to test the feasibility and impact of a cloud approach, and offer a practical example to other Danish IT initiatives (in the public or private sector). The expectation of cost reduction played only a secondary role.

NITA, in fact, does not own and manage any cloud infrastructure itself; this part of the platform is completely outsourced to a third party provider, Amazon. In other words Digitaliser.dk runs on a common 'off-the-shelf' cloud solution, rather than an ad hoc infrastructure.

¹³⁵ The information in this profile was kindly provided by M. Marc Andersen, NITA IT Security Analyst

¹³⁶ See (as of 22 November 2010) <http://digitaliser.dk/>

¹³⁷ For more information about Digitaliser.dk, see (both as of 22 November 2010) <http://ourdata.eu/node/65> and <http://www.epractice.eu/en/cases/digitaliserdk>

¹³⁸ See (as of 22 November 2010) <http://digitaliser.dk/resource/432461>.

¹³⁹ See (as of 22 November 2010) http://www.itst.dk/filer/Publikationer/hoejhastighedskomiteen/hoejhastighedskomiteen_del1/978-87-92572-06-9.pdf, p. 33 following on (in Danish)

7.5.2 Chosen cloud solution

As pointed out above, Digitalisér.dk is hosted in the cloud infrastructure of Amazon, a commercial cloud provider with whom NITA has concluded a standard business agreement. The standard Amazon cloud provision contractual terms were applied (see below for further information); no unique agreements were negotiated. Due to the limited scale and risk of the application, this was seen as an acceptable solution.

The cloud resources are not shared with other Danish institutions. NITA does not operate on behalf of other governmental entities, but simply decided to migrate Digitalisér.dk to a cloud model to test the potential benefits of the cloud without the ambition to immediately apply the experience gained to other services or government departments. NITA does not provide services and/or consultancy in the field of cloud computing. Of course, nothing impedes other public and private bodies following the example of NITA and deciding, based on the results of the use case, to migrate to the cloud as well.

Regarding, more specifically, the use case, the decision to migrate Digitalisér.dk to the cloud is based more on the will to test the potential of cloud computing than on the necessity to get more scalability, as might be required for larger social networks. Taking into account, in fact, that more or less 2,500 registered users were using Digitalisér.dk at the time the migration started, efficient scalability, when needed, could also be reached in a different (traditional) hosting environment. The chosen cloud solution of course offers scalability opportunities, but the use case indicates that the increase in flexibility may make it convenient to adopt cloud computing even if scalability is not a top priority for the user.

7.5.3 Risks and challenges of cloud use

This use case can be qualified as low risk, where data loss or service interruption would have no serious impact on individuals or on society. No crucial data or services are entrusted to the cloud, and the risk of significant damage is limited.

In particular, as regards privacy issues, no sensitive data are involved, in the sense that Digitalisér.dk processes only the names and email addresses of the registered users and no other data are stored in the cloud. Given the nature and objectives of this specific social network (which focuses on professional communications rather than private liaisons) no sensitive private data are processed, and therefore no important security issues or risks of significant damages are likely to arise. Furthermore, the terms of use of Digitalisér.dk expressly prohibit users from posting messages with sensitive content or uploading sensitive data.

In any case, NITA made a risk assessment before the migration to the cloud, and no particular problems and concerns were identified at the time that would be a barrier to the migration. This risk assessment, in fact, was principally focused on technical aspects, since privacy and security concerns were not likely to play a major role after the migration. The same assessment methodologies were used as for any other type of technology project (in other words, they were general questions essential to any such project, not specifically created for cloud projects).

Technical and business challenges too have been assessed as being limited, in the sense that the migration to cloud computing was not expected to (and did not) impact to a notable

extent the operation of Digitaliser.dk (according to the key paradigm of ‘business as usual’ – see below for further remarks).

7.5.4 Chosen approach to address these risks

Since the risks were low, NITA decided that the contractual terms of use of the cloud services contained in the Amazon’s Service Level Agreement (SLA) were acceptable (to be more precise, the contractual relations with Amazon are governed by the Amazon Web Services Customer Agreement and the Amazon EC2 Service Level Agreement).

Regarding privacy and security, the Amazon Web Services Customer Agreement states that:

11.6. Your Applications are Your Responsibility. [...] we specifically disclaim all liability, and you shall be solely responsible for the development, operation, and maintenance of your Application (including any Bundled Application) and for all materials that appear on or within your Application and you agree that you shall, without limitation, be solely responsible for:

[...]

11.6.4. ensuring that your Application accurately and adequately discloses, either through a privacy policy or otherwise, how you collect, use, store, and disclose data collected from visitors [...];

7.2. Security. We strive to keep Your Content secure, but cannot guarantee that we will be successful at doing so, given the nature of the Internet. Accordingly [...] you acknowledge that you bear sole responsibility for adequate security, protection and backup of Your Content and Applications. We strongly encourage you, where available and appropriate, to (a) use encryption technology to protect Your Content from unauthorized access, (b) routinely archive Your Content, and (c) keep your Applications or any software that you use or run with our Services current with the latest security patches or updates. We will have no liability to you for any unauthorized access or use, corruption, deletion, destruction or loss of any of Your Content or Applications.

11.2. Applications and Content. You represent and warrant: (i) that you are solely responsible for the development, operation, and maintenance of Your Content, including without limitation, the accuracy, security, appropriateness and completeness of Your Content and all product-related materials and descriptions; [...].

11.5. Disclaimers. [...] WE AND OUR LICENSORS DO NOT WARRANT THAT THE SERVICE OFFERINGS WILL FUNCTION AS DESCRIBED, WILL BE UNINTERRUPTED OR ERROR FREE, OR FREE OF HARMFUL COMPONENTS, OR THAT THE DATA YOU STORE WITHIN THE SERVICE OFFERINGS WILL BE SECURE OR NOT OTHERWISE LOST OR DAMAGED.

11.6. Your Applications are Your Responsibility. [...]We specifically disclaim all liability, and you shall be solely responsible for the development, operation, and maintenance of your Application (including any Bundled Application) and for all materials that appear on or within your Application and you agree that you shall, without limitation, be solely responsible for:
[...]

11.6.4. ensuring that your Application accurately and adequately discloses, either through a privacy policy or otherwise, how you collect, use, store, and disclose data collected from visitors[...].

The above clauses show that Amazon’s solutions (by default) are intended for low-risk use cases, since the cloud provider does not take any liability for the security of the content stored in the cloud. In the case of Digitalisér.dk it seemed that the contract proposed by Amazon was considered acceptable, since the benefits (reduced hosting costs) outweighed the risks and disadvantages (such as, at least de facto, absence of auditing rights and extensive guarantees).

From a more general perspective, NITA’s experience is that the focus on outsourcing is pivotal but the differences between cloud hosting and traditional hosting, from the business and technical point of view, are not as big as many may believe. Of course, the content of the contracts and SLAs that apply in the case study is different from that of SLAs that would be used under the previous hosting agreement, and the use of an ‘off-the-shelf’ solution precluded the possibility of asking the provider to modify some aspects of the cloud service provision.

In that respect, the business relationship with a larger cloud provider may be dramatically different from that with a traditional pre-cloud hosting provider. In the case of Amazon, standard terms will be applied unless the client has sufficient bargaining power.

As regards compliance controls, the EC2 SLA states that the user is entitled to service credits if Amazon fails to provide the cloud services at the promised level:

Service Commitment

AWS [Amazon Web Services] will use commercially reasonable efforts to make Amazon EC2 available with an Annual Uptime Percentage [...] of at least 99.95% during the Service Year. In the event Amazon EC2 does not meet the Annual Uptime Percentage commitment, you will be eligible to receive a Service Credit as described below.

The request of service credits and the Annual Uptime Percentage must be accepted and confirmed by Amazon, which then will proceed with the reimbursement of the credits.

From a technical perspective, the infrastructure used to deliver the cloud services to NITA is situated in the United States, or in other words Digitalisér.dk runs on cloud servers located in the United States.

In practical terms, the migration to cloud computing did not bring a radical change in comparison with the traditional hosting models that NITA was using before the advent of the cloud. It required only a limited amount of awareness raising with the clients, in the sense that they should understand that data and resources are stored in undefined placed, ie, in the cloud. Nonetheless, the application of technologies in cloud computing (principally the systematic use of virtualisation and hypervisors) is new, which was the key reason to test cloud computing and to see if it can fit the missions of NITA. Generally, the migration to cloud computing did not pose significant threats to Digitalisér.dk, and no new major technical risks and challenges were expected by NITA.

From a financial perspective, the expectation of a return of investment did not play a major role in the decision of NITA to migrate Digitalisér.dk to the cloud. However, the financial expectations are generally positive: NITA foresees that it will recuperate the migration costs within nine months of the migration; thereafter, cloud hosting should be marginally cheaper and thus realise small cost savings.

As regards training requirements for technical staff at NITA, little particular internal training has been required; this was partially due to the fact that much of the migration process was also outsourced. NITA provided the architectural specifications for moving to the cloud in the first place and managed the project as a whole. The online Amazon tutorials were useful to train the system administrators, who did not encounter major problems during the migration.

7.5.5 Experiences and lessons learned

The experience of switching to the cloud was largely positive. No major problems were faced, and in practice almost nothing changed in comparison with the hosting model followed before the migration. The main lesson learned is that migrating to the cloud is possible and that no major efforts are required, at least for this type of use case.

Furthermore, migrating has brought small financial benefits, as running Digitalisér.dk in a cloud computing environment is marginally cheaper than it was before. Since the reasons for NITA to migrate to the cloud related mainly to the desire to conduct a successful test and to reduce the hosting costs, the planned objectives have been reached.

More specifically, the key lessons can be formulated as follows:

- Understanding the technology: NITA increased its understanding of what cloud computing enables, but also the many parts that don't change. The approach is based on the idea that cloud computing is a form of outsourcing with more flexible technological characteristics, and in this sense the experience confirmed these expectations.
- Clearing up terminology and misconceptions: the cloud should be treated as an alternative technological approach which can be preferable to other hosting business models especially when scalability/flexibility is needed. From a business perspective, not much changed after the migration to the cloud, apart from the slightly reduced hosting costs.
- Applicability: cloud computing proved to be applicable to situations where no intense scalability is required.
- Business as usual: cloud computing does not imply dramatic changes in the business of the users, and little special training was required.

7.5.6 Remaining issues and concerns

NITA is confident that all relevant issues have been identified and addressed by the current solution, since no particular problems have been foreseen and/or appeared in reality. The system administrator and the people assigned to manage and follow Digitalisér.dk are well prepared and the migration to the cloud did not create difficulties for them.

NITA runs its business as usual and although cloud computing undoubtedly brought interesting advantages it did not revolutionise the use case. This applies also to users of Digitalisér.dk: for them, cloud computing did not change their experience of the web site, and this too was fully expected before the migration.

7.6 Case study 2: the City of Los Angeles

Los Angeles is the second largest city in the United States. The City of Los Angeles' core activities include the provision of municipal services (water, power, rubbish collection, etc.) for some 3.8 million residents. The City administration has 30,000 employees including 17,000 working for the Los Angeles Police Department (LAPD).

Their cloud computing project, termed Google Enterprise E-mail & Collaboration System (GEECS), was commissioned by the Information Technology Agency (ITA) of the City; it migrates the City's employees email and related systems to its Gov Cloud, a tailored version of the Google Apps suite designed for public sector use. The ITA provides all telecommunications regulatory services, cable television licensing and franchise enforcement, municipal cable programming and utilisation and operates the City's cable channel and related matters. It also has responsibility for planning, designing,

implementing and operating and coordinating the City's information technology systems and networks.¹⁴⁰

7.6.1 Description of the use case

The City of Los Angeles wanted to achieve a number of objectives in taking the decision to use GEECS. These objectives, including cost savings, technological flexibility and availability, are detailed below:

- Firstly, to acquire a state-of-the-art technology solution to drive productivity and efficiency and enable departments to move forward and communicate in ways that they have been unable to do so now.
- Secondly, to improve information provision – so that City employees can get whatever information they needs, when they need it, on whatever device they need it on, and also so they can collaborate on all sorts of documents, changing fundamentally the way the City conducts its business.
- Thirdly, to save money without the need for extensive capital outlay. It was predicted by the General Manager of the ITA that the City would be able to achieve US\$4–10m in hard savings, US\$5–10m in soft savings (avoided costs) and US\$10–20m in productivity enhancements (increased productivity resulting from the use of a common set of tools, such as calendaring, email and collaboration).
- Fourthly, to allow the reprioritisation of staff to other areas of technology deployment within the City that are currently understaffed.
- Finally, to improve availability: the high availability of Google Apps in comparison to the City's existing email system was noted. It was reported that the City experienced *c.*550 minutes of Post Office email failures and downtime in the twelve months between August 2008 and August 2009, compared to *c.*15 minutes of downtime experienced by Google Apps.

In internal discussions the fact that City would be the first major governmental entity to deploy a Google Apps system was also highlighted. However, reference was made to the use by the City of Orlando and Washington, DC, municipal authorities of Google products, as well by other large private sector organisations.

GEECS involves the migration of some 30,000 employees onto GovCloud. This cloud, representing a collection of Google Apps, includes a general system (for all staff) comprising email, antivirus and anti-spam, storage, archiving, e-discovery and training. Optional services per department were also provided such as an office productivity replacement, collaboration tools, file version control and storage virtual drives.

The commissioning of GEECS was highlighted in the media since Google appeared willing to enter into negotiations with the customer in order to secure the contract, specifically around a number of contractual concessions.

The migration schedule to GovCloud was relatively speedy, with non-LAPD employees migrating between January and July 2010, following a pilot of 3,000 users. This was

¹⁴⁰ See (as of 23 November 2010) <http://cityclerk.lacity.org/cps/pdf/govtglnc.pdf>

originally scheduled to be followed by full migration, by October 2010, of LAPD employees.¹⁴¹ However, as of August 2010, the LAPD had only 50 users testing the GovCloud environment,¹⁴² due to the additional protection requirements above and beyond that of the wider City.

7.6.2 Chosen cloud solution

In moving to the GEECS solution, Computer Sciences Corporation (CSC) was employed to implement, migrate and deploy Google Apps Premier Edition. Google Apps Premier Edition is a Software as a Service (SaaS) solution. This was chosen to replace an outdated deployment of Novell GroupWise used throughout the City municipal authorities for email. Once the system has been implemented, users are asked to accept, with an on-screen click, a separate usage contract with Google who run the system.

The contract is reportedly worth US\$7m to CSC and Google, although, according to reports, other state entities within both the City and County of Los Angeles will be able to take advantage of the services. This 'piggybacking' permits the City to receive pricing discounts on its contract if other additional entities choose to contract with CSC/Google. The savings were identified to be either US\$5 or US\$10 per person for each following year's annual payment, depending on the extent of further piggybacking on the contract by other state entities. Thus, all state and local government agencies are eligible to accede to the contract and as of September 2009, the ITA had received twenty 'serious' enquiries from other California state and local government agencies.

Observers have noted that a contract with CSC as the prime contractor and Google as the subcontractor is unusual in a cloud environment. However, this structural arrangement, in which a valued-added reseller (VAR), such as CSC, builds its services on top of the services provided by another company, such as Google, represented thirteen of the fourteen offers the City received in response to its invitation to tender, meaning that this type of legal construct was difficult to avoid. In this arrangement, the City only has a service contract with CSC, whereas it has only signed a non-disclosure agreement (NDA) with Google.

Google Apps Premier Edition is a purpose-built messaging and collaboration platform. The suite of applications includes solutions for business email, information sharing and security. Common services include email, word processing, spreadsheets, presentations, calendars and instant messaging without automatic saving. Additionally, under the solution proposed by CSC, further features such as Forms, multi-purpose wiki-style web pages and Google Video are provided. In the presentation of this offer to the City, the main business benefit was proposed to be the simplification of the creation, production and dissemination of information, enabling City workers to focus less on use of the technology and more on production of information. Other characteristics that were identified as potentially valuable by the municipality include the potential for seamless interoperability and easy collaboration. Finally, it was anticipated that the short learning curve and intuitive interface (together with the public popularity of Google Apps) would

¹⁴¹ Kevin Crawford, ITA, pers. comm. 16 July 2010

¹⁴² Maggie Goodrich, Police Administrator III, Information Technology Bureau, pers. comm. 2 August 2010

offer opportunities for reducing training time and minimising disruption caused by changing over from Novell GroupWise.

Nonetheless, as official documentation relating to the deployment illustrates, the cost issue was one of the key drivers. Financial management information from the City authorities indicated that continuing to use Novell GroupWise would involve considerable further expense. For example, the currently deployed solution for email was some generations behind the latest edition of the software and therefore updates, with requisite budgetary implication, would be required.

The Google Apps SaaS solution was integrated with the City of Los Angeles Identity Management (IDM) infrastructure, based on Lightweight Directory Access Protocol (LDAP) services, to enable more secure authentication than the standard username and password provided with the public Google Apps offering.

7.6.3 Risks and challenges of cloud use

This use case may be understood as medium risk, for two main reasons. Firstly, the sheer breadth of service and potential impacts resulting from interruption (email, archiving, anti-spam) represent one key set of indicators as to its risk level. Secondly, the particular security issues associated with the replacement of the LAPD's CLETS (California Law Enforcement Telecommunications System) prompted a range of discussions in the City's law enforcement and police community after the signing of the initial contract, but prior to deployment, regarding the security aspects of sensitive information relating to criminal investigations being stored in the cloud.

Since the LAPD has access to sensitive electronic data, any email system that it uses will have to be secure enough to allow the safe transfer of this information. As the sensitive data are held in accordance with Department of Justice (DoJ) requirements, the email system will also have to adhere to DoJ rules. These requirements, to be enforced by the LAPD, are that the data must be: encrypted to a known standard certified by NIST; held in an auditable system; and that background checks need to be conducted on those who have access to the data. These requirements were not in the original contract and there were initially objections from Google. This was due to the level of alterations required (Google does not generally use NIST-certified encryption, but rather obfuscation of data) and the new procedures insisted upon (the requirement to do separate background checks on Google staff for each user organisation of the GovCloud product). However, these conditions are now accepted by Google, and elements that do not currently exist, such as the auditing tools for the LAPD, have been placed on the road map for future development. The original contract between the City and CSC is in the process of being rewritten to reflect these alterations.¹⁴³

The alterations to reflect the requirements of the LAPD and the DoJ will build on the current version of GovCloud, 1.5, delivered on 22 June 2010, which holds sharded and encrypted data in one or more of three separate storage devices housed at existing US data centers.

¹⁴³ As at 3 August 2010

Other important challenges raised by the decision-makers include concerns relating to availability (eg, the consequences of a loss in Internet connectivity in key working areas), the knock-on effects of the deployment on other services (eg, whether the use of an Internet-based service will result in increased latency for other network applications), and the fact that disaster recovery is now entrusted to Google.

7.6.4 Chosen approach to address these risks

The associated contracts, SLAs and other agreements between the City of Los Angeles and both CSC and Google appear to be the main evidence of the approach to address the risks. So far, as the use case is in its preliminary phases, details of operational aspects and how the providers actually meet the requirements set out have not come to light. However, there is enough detail in the terms of the contracts to enable discussion on what legal, technical and other measures are present to provide for privacy, trust and security.

CSC (as the primary contractor to the City of Los Angeles) is required by the contract to establish a security programme to ensure the confidentiality and availability of protected information. The contract obliges CSC to comply with all federal, state, local and international law covering privacy and security. The City has a right to conduct a security audit and CSC has the responsibility to implement any security safeguards identified by the City in its audit. These audits can be on an ongoing basis, from time to time and without notice.

Additionally, CSC is required to undertake an SAS 70 or equivalent compliant audit of Google's information security programme and release the results of this audit to the City authorities upon request. However, as Google will be storing, processing and transmitting the data, audits from CSC may offer limited added value, depending on their scope (for example, whether CSC were permitted to check Google's infrastructure as well).

CSC is contracted to indemnify the City under certain circumstances, but there are caveats and limitations of liability (LOL). For example, there is no indemnification for breaches of privacy and security laws. Additionally, breaches outside warranty are subject to LOL.

It was stated in official documentation provided for the case study that Google has agreed in its contract with the City to provisions regarding a higher level of audit, transparency and security than normally offered as part of its cloud services. In practice, Google can perform a full audit in a two-week timeframe, and the City can itself audit individual emails spontaneously. However, the ability for the City to fully audit email communications is currently still under development.¹⁴⁴ Despite these abilities, the arrangement lacks details on incident response procedures, such as forensic investigations into data exposure.

Google is not contracted to comply with specific privacy and security laws, just federal and state breach notices. Ironically, if the City ends up violating relevant privacy laws, this may be viewed as a breach of contract on the part of the City.

There are also security provisions in the Google contract in relation to its 'facilities' but these apply only in respect of the contract between Google and CSC, rather than between

¹⁴⁴ As at 3 August 2010

the City of Los Angeles and Google. These provisions require that data from the City of Los Angeles is kept in facilities which adhere to 'reasonable security standards', similar to those in which Google stores and processes its own data.

The detail of this section of the agreement seems to indicate that Google regards its current systems to be 'compliant with industry standards'. Nonetheless, a purely legal interpretation of this form of compliance compared to reasonable security may be viewed as insufficient.

The SLAs contain confidentiality and privacy obligations, notably that CSC cannot disclose information to any third party without the City's written consent. 'Information' as defined by the NDA includes: 'technical information', 'business information', 'security' or 'rights'. The NDA makes it clear that the City retains ownership of all the information.¹⁴⁵

7.6.5 Confidentiality provisions

During the consideration and selection of Google Apps, security and confidentiality concerns were raised by the LAPD and City Attorney. According to official documentation, these concerns related to sensitive information, subpoenas and DoJ requirements. The Californian Department of Justice and the LAPD worked closely with the ITA during the design and preparation phases to ensure that confidentiality concerns were met.

In this situation the City retains ownership of the data, but the storage, processing and transmission of data has been entrusted to Google. If Google violates security and privacy laws, the City as 'data controller' is still liable. Thus, having a contract framed to prevent breaches, rather than to allow subsequent recovery or for the providing of financial compensation, may be best.

The CSC contract with the City allows for unlimited liability with respect to privacy and security breaches, and additionally responsibility for certain acts, errors and omissions by its sub-contractor Google.

Google's arrangement by comparison, contains broader confidentiality provisions which include customer data as confidential information (which by extension covers personal information stored, processed or transmitted through Google's services), as well as a stipulation that Google will refrain from disclosing confidential information. Google is required to protect such information 'with the same standard of care it uses to protect its own confidential information'. This distinction between an obligation not to disclose and an obligation to protect may suggest that Google is more comfortable with broader contractual security obligations than CSC. However, the arrangement does contain LOL and caveats for non-indemnification covering acts such as violation of privacy and security laws. Another point not defined in the arrangement is consideration of whether liability exists in respect of mandated disclosure (as might be required by law enforcement agencies).

¹⁴⁵ In the context of the regulatory framework of EU privacy and data protection laws, a practical comparison would make the City the 'data controller'

Both the CSC contract and Google arrangement contain provisions regarding compliance with relevant laws which would appear to be broad enough to include relevant privacy and data security laws.

Furthermore, technical measures have been deployed to address security, namely that other directory authentication procedures will be used to gain access to services, rather than the standard username and password used on Google's free public cloud offering. Additionally, City users will only be able to access Google services on City-run networks, provisioned mobile devices or via VPN, identical to how security was currently provided. To access data on GovCloud, a location key, an encryption key and a domain key are all required, meaning that one cannot access others' data. Rules regarding password rotation and strength will also continue to be enforced. City of Los Angeles email addresses are not publicly available from the Gmail directory and the City will continue to use its own email addresses (@LACity.org).

From a legal perspective the contract between Google and the City includes the following contract terms:

- Unlimited damages for a data breach
- Provisions allowing audits
- Guarantees that the data remain in the contiguous forty-eight states and that this is auditable
- Penalties if Google services are unavailable for any longer than five minutes per month
- Unlimited damages if the NDA is breached by Google
- Requirements for encryption and breaking data into pieces
- Bar on Google viewing data without permission from the City.

7.6.6 Experiences and lessons learned

The implementation of GovCloud has progressed successfully. According to the City, the cloud solution provides great versatility and swift updates. Certain workarounds have been used, but these are not detrimental. The VAR arrangement has worked relatively well, coupling Google and its interest in moving into the public sector and CSC's previous experience. Because of its experience in the public sector, CSC was able to accelerate the transition to Google's cloud-based services.

In the contract between CSC and the City, it was reported that there was insufficient due diligence undertaken by the City during the piloting stage. Problems arose during the migration regarding the incomplete transfer of contact and calendar information. Additionally, timelines were an issue as there was a miscommunication of deadlines and requirements between the City and CSC.

Regarding the interaction of the City with Google, since this was Google's first move into the public sector there were minor points of contention. However, the City was generally happy with the interaction.

The LAPD believed that the adoption of GovCloud was complicated by the internal arrangements within the department and by interactions with Google as a technical sub-

contractor.¹⁴⁶ Given that the project was led by the City's ITA without LAPD being present (despite the fact that they represented 40 percent of the final users), important topics were missed in the original contract, leading to contractual rewrites. Additionally, the chains of communication were perceived to be too long, with the LAPD having to liaise via CSC to talk with Google.

The LAPD focused on the protection of sensitive data, meaning that user interface issues were not as prominent as they should have been. Thus when interface issues were identified they had to be resolved late in the process, when ideally they could have been addressed considerably earlier.

Internally within the City, there has been some reluctance to migrate from Novell GroupWise to Google Apps. However, following initial opposition¹⁴⁷ Google has been extremely responsive in including additional features in their solution to better match those of GroupWise.¹⁴⁸ Of 100 feature requests, Google had implemented 70 by mid-July 2010.

As a matter of policy, City users were given access to both GovCloud and GroupWise for a week after the migration. This led to synchronisation complications, and other errors, which users blamed incorrectly on GovCloud. With the benefit of hindsight, the City would have preferred not to allow this simultaneous access. Additionally, the City emphasised the need for better communication and better training to keep its employees informed of changes.

The initially anticipated financial savings are hard to quantify, particularly with respect to additional features of GEECS. The GroupWise system is actually cheaper than a package containing just Google's email solution. However, once additional Google Apps are available to the LAPD and other departments, savings are expected to be realised via productivity enhancements.

7.6.7 Remaining issues and concerns

There are still a number of remaining feature requests, and further adjustments are expected to be identified with the migration of LAPD employees in late 2010. However, the City anticipates most of these will be addressed.

The LAPD is concerned about the level of trust that is being placed in Google. Google are to be contractually obliged to provide the required auditing tools, but these are still in development. They are expected in early 2011,¹⁴⁹ but given the sometimes strained relationship between Google and the LAPD, the latter will feel more comfortable when these tools are in existence and use.

Concern also exists within the City regarding a lack of employee buy-in to the migration to a cloud solution. However, the City expects cloud solutions in general to develop in the future and that its own solution will correspondingly improve. Improvements are expected

¹⁴⁶ Maggie Goodrich, Police Administrator III, Information Technology Bureau, pers. comm. 2 August 2010

¹⁴⁷ Ibid.

¹⁴⁸ Kevin Crawford, ITA, pers. comm. 16 July 2010

¹⁴⁹ Maggie Goodrich, Police Administrator III, Information Technology Bureau, pers. comm. 2 August 2010

to include increased storage space, additional products, and better collaboration, all of which will address some of the remaining employee concerns.

7.7 Case study 3: EU eHealth provider

The use case analysed here has been set up by a consortium of seven private entities in a specific EU Member State.¹⁵⁰ While the entities provide their own technical expertise with respect to cloud services and health care, Amazon delivers the physical cloud capability.

Other partners of the consortium include a regional medical council that provides patients' data and medical knowledge, entities providing pharmaceutical and medical information, and a social network web site, which has the main goal of distributing information among users.

7.7.1 Description of the use case

The use case involves the processing of patients' data in the cloud, thus it is a cloud experiment in the area of eHealth. Its purpose is to provide health data on specific patients in the chosen region, via a cloud infrastructure, to doctors of the same region. Doctors can retrieve the data directly and provide patients with treatment and medicaments.

The use case in question is run on a non-commercial basis: the main goal of the consortium is not to make profit but rather to test the possibilities of cloud computing in the area of eHealth and to assess if the use case can be extended to a national level. An important point is that the project was created *ex novo* in a cloud environment and was not running before under a different hosting model.

The data moved to the cloud are the following:

- Physicians' information (including address and contact details).
- Patients' health records: these do not relate to specific illnesses but rather are generic records including all relevant health-related information.
- General health information: this information is not related to any specific patient.
- Details and locations of medical centres and pharmacies: this information is generally useful for users and can be retrieved through a link with Google Maps (the same applies to the abovementioned physicians' information).

The tool, whose goal is that of sharing data and information about patients of the concerned region, is accessible only by doctors of that region. It is also accessible by patients, so that the list of users includes physicians and patients. Health insurance companies are currently excluded, but they may be included in the future. The system is still at an experimental level but nevertheless it is operational in the concerned region.

Regarding the main objectives to be achieved by the use case, the general (and ambitious) aim of the project is to get valuable information for physicians and other health care professionals from personal health information records (based on patient data) and a

¹⁵⁰ For the purposes of this study and at the request of the participants, this case study has been anonymised

general health information database (based on medical knowledge), and for consumers to get information on physicians, their locations and addresses (including a route map) in a given country, accessible on any device from any location.

The solution allows interaction between patients and doctors in the sense that:

- Doctors can retrieve information about patients from the cloud, so that every physician can obtain detailed information about the patient even if he/she never seen the concerned patient before.
- Patients can obtain information about names and locations of doctors in the whole region (and potentially throughout the whole country).

7.7.2 Chosen cloud solution

The use case falls into the category of public and non-commercial cloud implementations, since the goal is not that of making profit but rather to propose an open solution for doctors and patients in a specific region. The cloud solution adopted is public in the sense that it uses the infrastructure of Amazon and not an ad hoc cloud.

The consortium, in fact, decided to adopt the cloud solutions offered by Amazon mainly because of their low hosting costs.

7.7.3 Risks and challenges of cloud use

The use case presents important risks and challenges, especially in the area of privacy and security threats. While data loss or service interruption has no direct impact on the user's health or safety, crucial (patients') data are entrusted to the cloud, meaning that there are substantial privacy challenges to be managed. The risk of significant damage to the quality of health care is limited, since no data perceived as of critical importance from the operational or business perspective are uploaded in the cloud, and above all because in case of technical problems or failures, doctors can retrieve patients' data using other means. The solution does not aim to substitute traditional health records but rather to complement them, so that physicians have alternative and more efficient ways of retrieving patients' data and information.

The consortium was and is fully aware of the privacy issues that the use case concerns and that they need to be carefully managed in order to avoid major incidents. Although the failure of service would not cause much damage, no major technical risks are involved, and no lock-ins are expected, the consortium felt that the data were very crucial with lot of privacy involved. For this reason, they performed a systematic risk assessment before starting the project. See below for further information about the solutions adopted.

7.7.4 Chosen approach to address these risks

The main security and privacy issues have been addressed by a careful contractual architecture and through technical means. From the legal perspective, the consortium realised that the standard Amazon SLA was not sufficient to mitigate the privacy risks. They managed to negotiate with Amazon the content of an ad hoc SLA, which is very similar to the standard SLA and users' terms of Amazon but differs in one sensitive clause.

Amazon agreed to store all the data uploaded by users in the framework of the use case only in servers inside the European Union, with the further commitment not to migrate the data to cloud components outside the European Union itself. Three issues should be

highlighted: (i) this contractual arrangement has been signed by Amazon and by the leading partner on behalf of the whole consortium; (ii) the modified SLA and users' terms are intended to avoid privacy risks and reduce compliance costs for the consortium, which is now not obliged to obtain authorisations from the national privacy authority concerned for the export of data outside the European Union; and (iii) the other standard clauses of Amazon's SLA and users' terms basically remain applicable.

It should also be pointed out that no specific maintenance agreements have been signed and that the consortium has auditing rights towards Amazon, which can thus be audited by the consortium itself. Generally speaking, this auditing right is not common, but it is necessary due to the nature of the sensitive data involved. External legal auditors are involved in the use case as well.

From a technical point of view, guidelines such as incident handling mechanisms, logging obligations, and so on, have been established. Regarding incident handling mechanisms, a complete backup of all data is regularly performed but no other tools have been foreseen. There are no dedicated servers to be used in case of incident. The consortium believes that Amazon is reliable enough for the hosting of the patients' data, and as pointed out above the loss of such data would not impede the treatment of patients by doctors.

As for the timing of the use case, it started in December 2009 and after 2 weeks of trial period, the experiment proper began. The use case was revealed to be stable during the trial period; presently it is still in the experimental phase before full and definitive implementation. It is foreseen that a business continuity plan will be drafted and implemented after this experimental phase is complete.

From an operational perspective, no migration planning was needed, since the data stored in the cloud were not previously hosted under a different hosting model. Only limited staff training was required, since many of the people involved in the consortium had previously gained experience with cloud computing and therefore were already familiar with the technology. They are aware of the risks and challenges of cloud computing. Training is rather more required at the doctors' side, and it was (and still is) necessary to provide physicians with detailed information about the operating modalities of cloud computing.

Finally, in brief, the primary advantage of this project is that the data of patients from a particular region of a European Member State are made available via a cloud provider in Europe to be retrieved by doctors in the same region. Patients too can obtain information on relevant physicians. Although the use case does not fall in the area of e-government (no public institutions are involved in the project), no revenues are foreseen, no fees will be charged, and the use case is operated on a non-commercial basis.

7.7.5 Experiences and lessons learned

The use case brought (and continues to bring) valuable insights to the consortium. In particular, the following issues need to be highlighted:

- Although the case study envisions an integrated platform linking hospitals and healthcare centres across the region (and potentially within a country) allowing secure access to shared information with patients' records instantly available, the support from the health centres and physicians was not complete as some were afraid to entrust patients' data to the cloud due to

privacy concerns. In other words, even if the benefits arising from the use case are notable for the users (especially for doctors), some health professionals felt that the risks involved were very substantial. Nonetheless, some 75–80 percent of the physicians of the region concerned did participate in the project and shared their patient data in the cloud.

- The project seems to be viable and interesting so that a further implementation at national level would be desirable.
- However, such further implementation would be more difficult to realise, with greater risks of confusion when a huge amount of data are migrated to the cloud. Although hosting costs and possibilities are not big concerns, since cloud computing is potentially unlimited and relatively cheap, the migration of large amounts of sensitive data is not a trivial task.
- The use case does not pose significant problems and difficulties from the technical point of view; major issues, however, are expected to arise if the consortium decided to change cloud provider and to migrate all data to the new supplier, due to the need to extract and relocate substantial amounts of highly sensitive data.

Generally speaking, the use case brought benefits in the sense that doctors could more easily obtain detailed and updated information about patients of the region even if they did not know a patient personally and had not treated them before.

7.7.6 Remaining issues and concerns

The implementation of the use case required a high level of care considering the sensitive nature of the data involved. Due to this, the consortium adopted a phased approach to meet the needs of various stakeholders (in particular doctors) and embraced best practice recommendations. They have also engaged users in the process and in joint application development.

However, although 75–80 percent of the physicians in the concerned region did collaborate with the project, reluctance to provide patients' data may be an issue if the use case should be further developed and extended to the national (or even international) level. Obtaining the consent of the doctors involved in the experiment to provide patients' data was not an easy task.

In general the project has been well received and future plans of further nationwide implementation are under discussion. There are, of course, still issues to be carefully assessed, such as respect of doctors' professional secrecy. In this sense it may be recommended that the local or national physicians' associations are involved and provide the consortium with guidelines, recommendations and useful tips about how to avoid the processing and undue disclosure of information covered by professional secrecy.

Security is also a major topic, since it is absolutely essential that the cloud solution envisaged eliminates security threats as much as possible. An open cloud may not be the best solution, but in any case the experiment, which for the moment runs on a commercial open cloud infrastructure, demonstrated that cloud computing may bring benefits in the field of eHealth.

7.8 Implications

This section presents an analysis of the primary risks and challenges, along with the observed strategies to address these, arising from the practical implementation of the case studies described. The use of third-party cloud computing services can be considered as a form of outsourcing with more flexible technological characteristics: therefore a key question is if and how the existing policy and regulatory framework is capable of handling this increased flexibility. Is it necessary to rewrite the regulatory rule book in order to deal with cloud computing? And what dynamics or aspects (if any) are different enough to warrant specific regulatory intervention? Some of the emergent issues arising from the case studies are presented below.

7.8.1 Cloud computing is still experimental

Whichever way cloud computing is defined, from a pragmatic perspective cloud computing deployments have been around for only 2–3 years. In this space of time, many organisations implementing cloud computing have barely got to grips with the realisation of commercial benefits, let alone grappling with the complex issues of security. With that in mind, based both on the interviews with stakeholders and the case studies above, it seems that organisations are growing increasingly keen to experiment with cloud-based models to try to take advantage of the supposed benefits, whilst relegating compliance and security issues to a secondary role (or even not considering them at all).

As will be explored further in this report, each of the case studies revealed specific challenges or weaknesses which were not identified until a relatively late stage in the project, or not at all, such as:

- The lack of specific provisions with respect to personal data exports in the Danish use case, based on the consideration that a social network was estimated to be a low-risk application.
- The regulations with respect to confidential information established by the Department of Justice in the Los Angeles use case.
- The issue of patient consent with health care information processing in the eHealth use case.

Especially in an era of economic crisis, companies may be inclined to choose the presumed economic benefits of cloud solutions and leave the more ambiguous compliance and security issues for a later stage. This obviously creates risks that need to be managed at some point.

7.8.2 Moving to the cloud makes it even more imperative to be fully aware of your own risk tolerance and security level

Cloud providers (much like any other type of service provider) offer standard terms with generally limited guarantees in respect of privacy and security. This is not a problem provided that the users of cloud services have the diligence and negotiating power to identify their own risks and responsibilities, and to seek appropriate solutions when standard terms are inadequate. For those cloud customers that have more unique or complex security arrangements and are aware of them (as in the eHealth and LAPD cases), they can negotiate tailored SLAs which permit a greater degree of assurance.

One consequence is that cloud customers have to be more aware of their security needs before embarking upon a cloud deployment, lest they accidentally outsource risks that they were insufficiently aware of to the cloud service provider (who may decline any liability for these risks under its standard terms). So, paradoxically, the benefits gained in terms of reduced capex from moving to the cloud might be lost if it is sunk into understanding the internal security landscape and risk tolerance.

On the other hand, it should also be recognised that this risk is not entirely new or unique to the cloud: any type of outsourcing contract involving sensitive data or services requires due diligence on the side of the outsourcing party, along with a framework to ensure that liabilities and guarantees are correctly managed. The main new element in the cloud is the greater degree of flexibility and complexity with respect to the data and services, which requires appropriate provisions (eg, with respect to applicable law, competent courts, location where data/services will be hosted, and SLAs).

These issues are not unique to cloud services, but have become much more apparent due to the global scale on which cloud service providers operate, the smaller inherent transparency of their infrastructure, and the perception of greater operational ease of use which often belies the complicated legal and trust requirements behind a project (even if it is cheap and simple to move into the cloud, that does not necessarily mean that compliance, security and trustworthiness will be equally cheap and simple). On this point, cloud projects require a greater degree of diligence, at least until users have more experience with this type of model.

7.8.3 Can cost drivers override security?

Another challenge consistent with take up of new technology or computing paradigms by customers is the extent to which cost concerns can override security. This may be seen in the City of Los Angeles case study where despite the LAPD representing the majority end user community of the case study, six months after initial deployment only 50 LAPD users were converted to the system. This was due to ongoing concerns regarding security. In current harsh financial climate, it can be seen that this might evolve to become even more of a pressing concern. In the case of the LAPD the cost drivers were significant with expected gains in the tens of millions of dollars; nonetheless, the security issues associated with the replacement of the LAPD's CLETS prompted a range of discussions in the city's law enforcement and police community after the initial contract was signed but before deployment began to this class of users. Indeed the auditing tools for the LAPD system are now being placed on the roadmap for future development.

7.8.4 Integration with existing security measures

The City of Los Angeles demonstrated with its use of Lightweight Directory Access Protocol (LDAP) authentication that integration with existing IDM infrastructures is possible in a cloud computing deployment. Indeed, it may be that this is the only way to retain assurance of certain aspects of security or privacy controls, given the challenges for cloud computing outlined in the literature assessment. The lesson, therefore, is that whilst contracting out to the cloud may improve the overall security position of an organisation (since cloud computing can also have positive aspects for security), this is not a foregone conclusion (except in cases where no real security measures existed beforehand, which may well be the case for smaller organisations, including SMEs). However, especially in cases

where more sensitive information is entrusted to the cloud, any inherent security characteristics of the desired cloud would have to be carefully measured against security needs in order to assess if further steps would be necessary. It is not always possible to go from a no security situation to a more secure situation simply by turning to cloud services; rather, some initial security and trust mechanisms will typically need to be in place in the cloud customer organisation prior to any deployment, especially in medium or higher risk application fields.

7.8.5 **Untoward dependencies can be a problem**

One of the operational challenges cited by the City of Los Angeles case study regards Internet connectivity and the availability challenges presented by the reliance on a service so heavily dependent upon Internet connectivity. Although many approaches to mitigating this risk focus on considering availability at the end point (eg, via mechanisms to keep some kind of offline last-known good representation of the data), what is not considered is how the resilience requirements evolve in a cloud computing deployment and how it may require potential cloud users to devote more consideration to their own resilience (eg, whether they have dual home Internet connections with (physically and logically) separate service providers).

7.8.6 **Granularity is possible (but only if you have the right cloud provider and sufficient negotiating power)**

Cloud computing services are often likened to utility services ‘on tap’: they offer a homogenous service which can be elastically increased or decreased as needed in a relatively easy fashion that requires limited technical expertise and which is ultimately cost effective to the user. However, this metaphor also suggests a weakness, namely that of offering a standardised product with limited customisability, which may not match cleanly with the end users’ needs. This begs the question: can a cloud service user realistically obtain customised service levels that ensure compliance with technical, legal and operational requirements?

Both the City of Los Angeles and the EU Member State eHealth case studies show that a degree of customisation of ‘off-the-shelf’ cloud solutions is in fact possible. For instance, in both of these cases questions of data location were dealt with in a slightly more granular fashion to address specific needs. In the case of GovCloud, Google has asserted that data will be held in three separate storage devices located within existing US data centres and that this is auditable. In the case of the EU Member State eHealth case study, the contractor asserted not to place sensitive patient data outside of the EU, in order not to run afoul of personal data export rules. Nonetheless the ability to achieve this is clearly dependent upon the intersection between the cloud customer and the market: if the main cloud providers are based outside of Europe then they might be less inclined to meet contractual requirements of EU-based companies who stipulate, for example, that all personal data must be kept within the EU.

The same observation applies in relation to other crucial issues to be governed through contractual terms, such as applicable law, competent courts, auditing rights and possibilities, etc. Again, this issue is not unique to cloud computing, as it manifests itself in precisely the same way as with traditional outsourcing projects: both parties will have their standard terms, preferences and prerequisites, and the final result will typically depend on

negotiating power. In that respect, it is worrisome that the leading cloud service providers (including those identified in the two EU use cases) are established outside the EU, as this implies that EU law will typically not apply unless users of cloud services manage to negotiate a favourable outcome on this point. This is also relevant because it implies that EU regulatory intervention with respect to cloud service providers is unlikely to have a real market impact: key service providers are simply not subject to EU law. Rather, effective policymaking should target the users of cloud solutions, who may well be European and subject to EU requirements, as (again) the two EU case studies show.